

Red Team Assessment Report

External Network Penetration Test — Q2 2025

CLIENT: ACME CORPORATION

TABLE OF CONTENTS

1. Executive Summary	
2. Scope & Methodology	
3. Findings	
4. Test Coverage	

EXECUTIVE SUMMARY

This report presents the findings of an external network penetration test conducted against Acme Corporation's internet-facing infrastructure during Q2 2025. The assessment identified five vulnerabilities ranging in severity from Informational to Critical.

The most significant finding — a Critical severity Log4Shell RCE — poses an immediate risk of full system compromise and requires urgent remediation. The security posture of the environment requires significant improvement before it can be considered adequately hardened against determined adversaries.

SCOPE & METHODOLOGY

The assessment was conducted using a black-box methodology from an external, unauthenticated perspective.

In-scope assets included all systems accessible on the ASN 12345 block and the following hostnames: web-app.acme.com, api-gateway.internal, cdn.acme.com, legacy-api.acme.com.

FINDINGS

Severity Distribution

CRITICAL		1
HIGH		1
MEDIUM		1
LOW		1
INFO		1

Detailed Findings

F01 Remote Code Execution via Log4Shell (CVE-2021-44228)**CRITICAL****AFFECTED ASSETS** api-gateway.internal, auth-service.internal**CVSS** 10.0**DESCRIPTION** A critical unauthenticated RCE vulnerability was discovered in the Apache Log4j logging library used by the client's internal API gateway.**IMPACT** An attacker can achieve full system compromise and lateral movement across the internal network.**STEPS TO REPRODUCE** 1. Send a crafted JNDI lookup string in the User-Agent header. 2. Observe callback to attacker-controlled LDAP server. 3. Deliver malicious Java class payload.**RECOMMENDATIONS** Upgrade Log4j to version 2.17.1 or later. Apply WAF rules to block JNDI patterns. Audit all Java applications.**F02 SQL Injection in Customer Search Endpoint****HIGH****AFFECTED ASSETS** web-app.acme.com**CVSS** 8.8**DESCRIPTION** The /api/customers/search endpoint does not properly sanitise the 'query' parameter, allowing an attacker to inject arbitrary SQL.**IMPACT** Full database read access; potential for data exfiltration of PII.**STEPS TO REPRODUCE** 1. Supply ' OR '1'='1 as the query parameter. 2. Observe all customer records returned.**RECOMMENDATIONS** Use parameterised queries. Apply input validation. Review all data-access layer code.

F03 Directory Traversal on File Download Feature**MEDIUM**

AFFECTED ASSETS	cdn.acme.com
CVSS	6.5
DESCRIPTION	The file download functionality does not canonicalise file paths, allowing traversal outside the intended directory.
IMPACT	Read access to sensitive server-side configuration files.
RECOMMENDATIONS	Canonicalise all user-supplied paths. Implement an allow-list for permissible download directories.

F04 Missing HTTP Security Headers**LOW**

AFFECTED ASSETS	web-app.acme.com
CVSS	3.1
DESCRIPTION	Several important HTTP security headers are absent from all responses, including X-Frame-Options and Content-Security-Policy.
IMPACT	Increased exposure to clickjacking and XSS attacks.
RECOMMENDATIONS	Configure the web server to emit X-Frame-Options: DENY, CSP, and HSTS on all responses.

F05 TLS 1.0 Supported on Legacy API Endpoint**INFO**

AFFECTED ASSETS	legacy-api.acme.com
DESCRIPTION	The legacy API endpoint supports TLS 1.0 which is deprecated and should be disabled.
RECOMMENDATIONS	Disable TLS 1.0 and 1.1. Enforce TLS 1.2 as minimum. Prefer TLS 1.3.

TEST COVERAGE

No test cases recorded.

